



GRC Unplugged: Smart Assessment, Fast Implementation, with Agentic AI

Dulu GRC dilakukan secara manual. Sekarang tools semakin pintar, dan AI mulai membantu pekerjaan GRC — dari mencari dokumen, membuat checklist, memeriksa evidence, mencari gap, hingga membuat laporan.



Mengapa GRC Terasa Berat?

Regulasi → Policy → Control → Evidence → Assessment → Audit. Rantai ini menghasilkan pekerjaan manual yang terus menumpuk.

Dokumen Banyak

File tersebar, evidence harus dicari satu per satu.

Checklist Manual

Setiap checklist diperiksa satu per satu secara manual.

Laporan Lama

Membuat laporan membutuhkan waktu yang lama.

Pekerjaan Berulang

Tugas yang sama dilakukan berulang-ulang setiap siklus.

Masalah GRC bukan kurangnya aturan – tetapi terlalu banyak pekerjaan manual untuk mengelolanya.

Semua Dimulai dari Excel

Regulasi → Policy → Control → Evidence → Assessment → Audit. Rantai ini menghasilkan pekerjaan manual yang terus menumpuk.

Requirement	Evidence	Status	PIC
Access Control	Policy IAM		IT
Backup	Backup Report		Infra
Awareness	Training Record		HR

✓ Kelebihan

Murah, mudah dibuat, fleksibel.

⚠ Kekurangan

Mudah salah, sulit dikontrol, sulit untuk banyak framework.

Excel bukan salah – hanya mulai kewalahan ketika GRC semakin kompleks.

Excel Digantikan Sistem

GRC tools mulai membantu mengelola Risk, Compliance, Audit, Policy, Evidence, dan Dashboard dalam satu sistem terpadu.

Lebih rapi, tracking lebih mudah, workflow lebih jelas, dashboard tersedia.

Tetapi manusia tetap harus membaca, mencari, membandingkan, dan menilai.

Dulu

"Mana file evidence untuk control ini?"



Sekarang

Sistem sudah menyimpan dan menghubungkan evidence dengan control.



GRC Modern: Pilihan Produk di Pasar

Berbagai vendor menawarkan solusi GRC yang komprehensif, masing-masing dengan kekuatan dan spesialisasi unik. Memilih yang tepat tergantung pada kebutuhan spesifik organisasi Anda.

Produk	Spesialisasi	Kemudahan Penggunaan	Skalabilitas	Integrasi	Cocok Untuk
Archer (RSA)	GRC holistik, Risk Management	Moderate	Sangat Tinggi	Tinggi	Perusahaan besar, kompleksitas GRC tinggi
ServiceNow GRC	IT GRC, Manajemen Risiko Operasional	Moderate	Tinggi	Sangat Tinggi	Pengguna ServiceNow, IT-centric GRC
AuditBoard	Internal Audit, SOX Compliance	Tinggi	Moderate - Tinggi	Moderate	Tim audit, kepatuhan finansial
Workiva	Reporting, Regulatory Compliance	Tinggi	Tinggi	Moderate	Pelaporan finansial, ESG, SOX
LogicGate	Risk & Compliance Management, Automasi	Tinggi	Moderate	Moderate	Automasi proses risiko, perusahaan menengah
Domo	Analitik, Dashboard GRC	Tinggi	Tinggi	Sangat Tinggi	Analisis data GRC mendalam, dashboard kustom
Nessus/Qualys	Vulnerability Management, Security Compliance	Moderate	Tinggi	Tinggi	Keamanan IT, kepatuhan teknis

Memahami perbedaan ini akan membantu organisasi mengidentifikasi platform yang paling sesuai untuk kebutuhan GRC mereka, baik untuk manajemen risiko komprehensif, kepatuhan spesifik, atau analisis data mendalam.

Sekarang Kita Bisa Bertanya kepada AI

AI dapat membaca dokumen, merangkum, mencari informasi, membandingkan, dan membuat draft. Tetapi AI Assistant / AI Chatbot masih menunggu kita bertanya – seperti Google Search yang jauh lebih pintar.

 **User**

"Apa requirement ISO 27001 untuk access control?"

 **AI**

Menjelaskan requirement, lalu membandingkan dokumen dan memberikan indikasi gap.

Apa Itu Agentic AI / Vertical AI ?

User memberikan tujuan: "Saya ingin mengetahui apakah aplikasi saya siap diaudit."

Mencari
requirement

01

Mencari
evidence

02

Memeriksa
dokumen

03

Menemukan
kekurangan

04

Membuat
daftar gap

05

Memberikan
rekomendasi

06

Meminta manusia mengambil
keputusan bila diperlukan

07

Agentic AI adalah AI yang tidak hanya memberikan jawaban, tetapi dapat menjalankan rangkaian pekerjaan untuk mencapai suatu tujuan.

Produk dan Platform untuk Membangun Agentic AI

Berbagai produk dan platform tersedia untuk membangun Agentic AI, masing-masing dengan kekuatan unik untuk mengotomatiskan tugas GRC.

Platform	Kemudahan Penggunaan	Integrasi GRC	Potensi Use Case GRC
OpenAI Assistants API	Tinggi (melalui GPT)	Sangat baik (API-centric)	Otomasi tugas spesifik, klasifikasi dokumen kepatuhan, ringkasan regulasi
Anthropic Claude API	Tinggi (tool use)	Sangat baik (API-centric)	Analisis risiko, validasi bukti, penulisan laporan awal
Google Vertex AI Agents	Moderate - Tinggi	Komprehensif (ekosistem GCP)	Platform agen kustom untuk integrasi data enterprise dan model AI yang disesuaikan
LangChain	Moderate (developer-focused)	Sangat fleksibel (open-source)	Prototyping cepat, pengembangan alur kerja agen GRC yang sangat disesuaikan
AutoGen (Microsoft)	Moderate (developer-focused)	Fleksibel (multi-agent system)	Simulasi skenario audit, sistem multi-agen untuk evaluasi kontrol kompleks
Crew AI	Moderate (developer-focused)	Fleksibel (orquestrasi agen)	Manajemen proyek kepatuhan, orkestrasi tim agen untuk proses GRC
Dify	Sangat Tinggi (no-code/low-code)	Mudah (API/Plugin)	Otomatisasi cepat untuk workflow GRC sederhana, pembuatan aplikasi GRC

Pemilihan platform harus mempertimbangkan **kemudahan integrasi** dengan sistem GRC yang ada, **kemampuan mengakses tools dan API lain**, **monitoring dan logging** untuk audit, serta **biaya dan skalabilitas**.

Kalau AI Bisa Bertindak, Siapa yang Mengontrol?

Bayangkan AI diberi akses ke dokumen, data, email, dan sistem GRC. Pertanyaan kritis muncul:

Apa yang boleh dan tidak boleh dilakukan AI?

1

Kapan harus meminta persetujuan manusia?

2

Siapa yang bertanggung jawab?

3

Bagaimana mengetahui dan menghentikan AI bila salah?

4

Semakin pintar AI, semakin penting pengawasannya.



Kalau AI Bisa Bertindak, Siapa yang Mengontrol?

Gunakan 5 aturan sederhana ini sebagai panduan:

01

Tentukan Tugasnya

Spesifik: "AI untuk compliance gap assessment" — bukan "melakukan semuanya".

02

Batasi Akses

AI hanya mendapatkan data dan sistem yang diperlukan.

03

Tetapkan Batas Tindakan

● Boleh otomatis: mencari dokumen, ringkasan, draft. ●
Review manusia: severity, risk rating. ●
Tidak boleh: ubah sistem produksi, hapus data.

04

Catat Semua Aktivitas

Siapa meminta? AI melakukan apa? Data apa digunakan? Apa hasilnya?

05

Manusia Tetap Bertanggung Jawab

AI membantu pekerjaan — manusia tetap memegang keputusan penting.

AI Governance: Kerangka Kerja dan Regulasi

AI Governance adalah kerangka kerja sistematis untuk mengelola risiko, kepatuhan, dan etika yang muncul dari pengembangan dan penggunaan sistem AI. Tujuannya adalah memastikan AI digunakan secara bertanggung jawab dan selaras dengan nilai-nilai organisasi serta harapan masyarakat.

Komponen Utama AI Governance:

Risk Management

Mengidentifikasi, menilai, dan memitigasi risiko terkait AI.

Compliance

Memastikan kepatuhan terhadap hukum, regulasi, dan standar.

Ethics

Menerapkan prinsip moral dalam desain dan operasional AI.

Transparency

Menyediakan visibilitas tentang cara kerja dan keputusan AI.

Accountability

Menentukan siapa yang bertanggung jawab atas tindakan AI.

Human Oversight

Memastikan manusia memiliki kontrol dan pengawasan atas AI.

EU AI Act

Regulasi komprehensif untuk AI di Eropa.

NIST AI RMF

Framework manajemen risiko AI dari AS.

ISO/IEC 42001

Standar internasional untuk sistem manajemen AI.

Singapore's AI GF

Kerangka kerja governance AI Singapura.

China's AI GG

Pedoman governance AI dari Tiongkok.

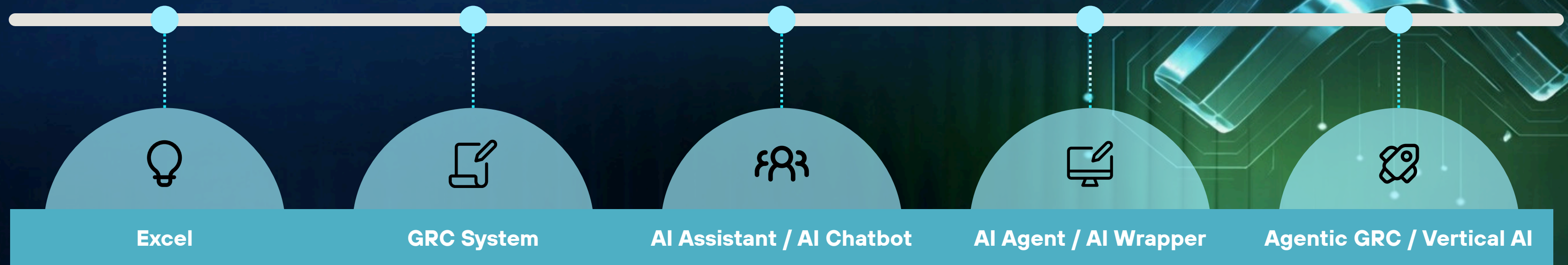
GDPR

Perlindungan data pribadi dalam konteks AI.

Responsible AI Principles

Berbagai prinsip etika dari organisasi global.

GRC Tidak Hilang. Cara Kerjanya yang Berubah.



Di masa depan, ketika regulasi baru muncul, AI dapat membaca regulasi, mencari requirement, mencocokkan control, mengidentifikasi gap, dan memberikan rekomendasi – lalu menyerahkan kepada manusia untuk review.

Tujuan Agentic AI bukan menggantikan manusia dalam GRC — tetapi mengurangi pekerjaan manual dan repetitif, sehingga manusia dapat lebih fokus pada risiko, keputusan, dan governance.